

EC-Council



ISTITUTO ELVETICO
FORMAZIONE PROFESSIONALE

MODULO
01

*Cyber Security:
Fundamentals*

Cyber Security: Fundamentals

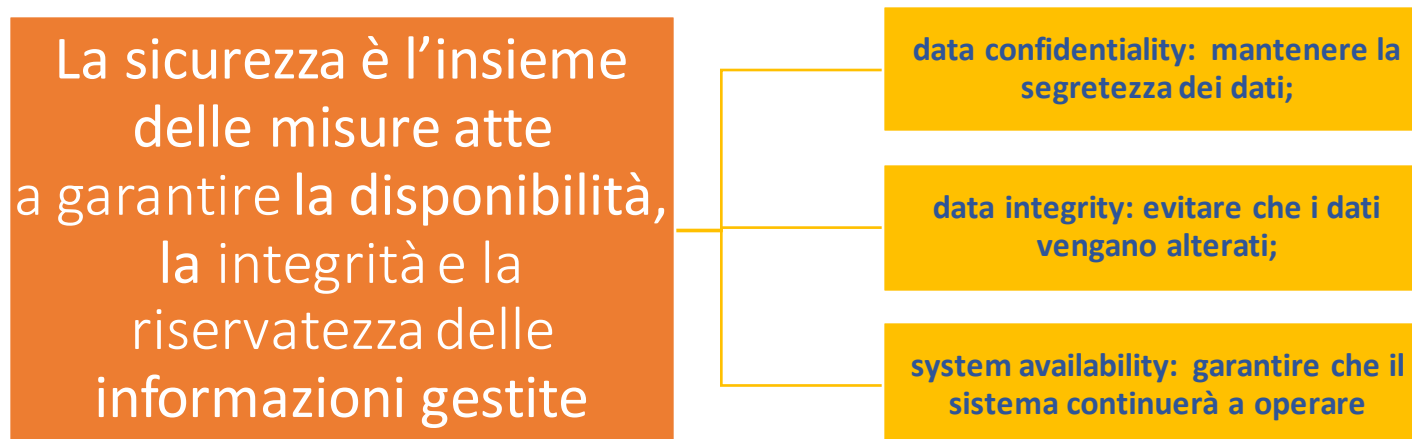
Cos'è la SICUREZZA INFORMATICA

- Con il termine sicurezza informatica si intende lo studio dei *problemi* connessi alla sicurezza delle informazioni e delle *soluzioni* che vengono escogitate per fronteggiarli.



Cyber Security: Fundamentals

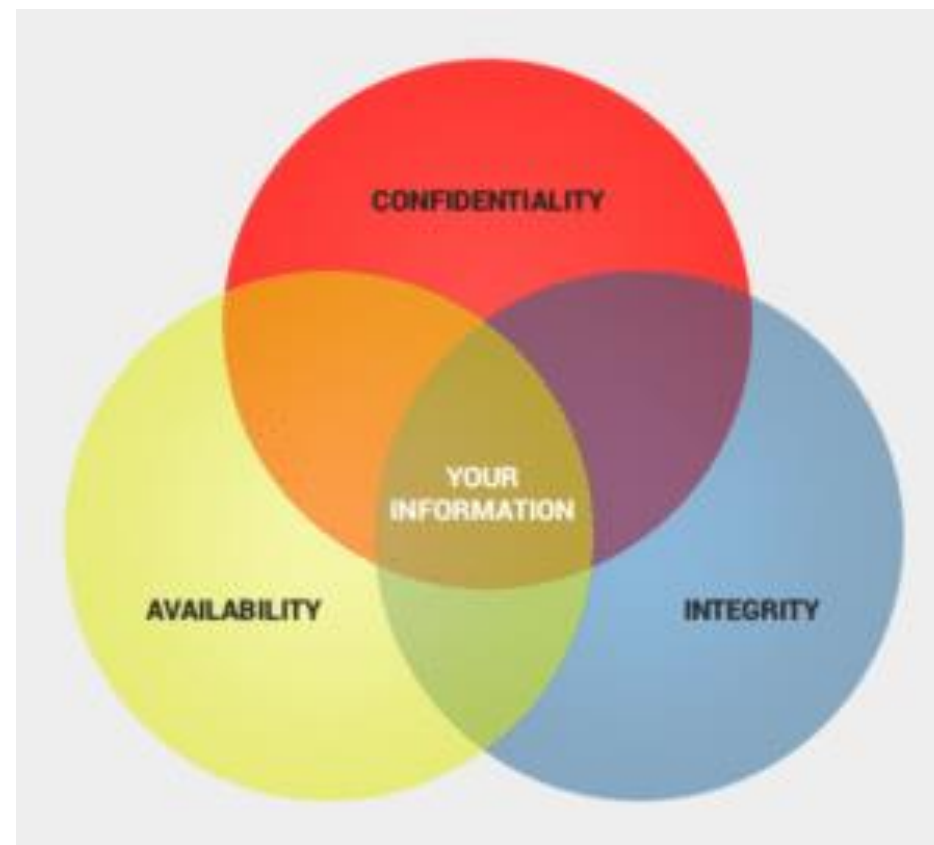
- Con il termine sicurezza informatica si intende quel ramo dell'informatica che si occupa delle analisi delle minacce, delle vulnerabilità e del rischio associato agli asset informatici, al fine di proteggerli da possibili attacchi (interni o esterni) che potrebbero provocare danni diretti o indiretti di impatto”.



Prevenzione e Protezione

Paradigma CIA (Confidentiality, Integrity and Availability)

- Solo attraverso un corretto equilibrio tra confidenzialità, disponibilità ed integrità, possiamo parlare di Sicurezza dei dati.
- Fare proprio questo equilibrio, potrà aiutare il Security Manager, nella valutazione del:
 - ✓ Rischio informatico
 - ✓ Attacco informatico



Protezione degli Asset Informatici

RID o CIA Triad

- La protezione degli asset informatici è ottenuta attraverso misure di carattere tecnico ed organizzativo, sia di prevenzione che di protezione, tese ad assicurare:
 - ✓ l'accesso protetto e controllato ai dati, a garanzia della confidenzialità delle informazioni trattate (proprietà di riservatezza) → R
 - ✓ la consistenza dei dati, intesa come completezza e correttezza degli stessi (proprietà di integrità) → I
 - ✓ l'accesso ai dati nei tempi e nei luoghi previsti (proprietà di disponibilità) → D
- Le proprietà di integrità, riservatezza e disponibilità (RID) dei dati costituiscono l'assunto base sul quale vengono svolte tutte le successive valutazioni di sicurezza. Tali proprietà sono in genere affiancate anche dalla proprietà di non ripudio, ovvero dalla possibilità di attribuire un dato ad un mittente o proprietario ben identificato.

Cos'è il RISCHIO INFORMATICO

- Un rischio, al di là delle interpretazioni più intuitive, viene definito in ambito aziendale come **“una possibilità di perdita o di esposizione ad una perdita”**;
- Il rischio viene solitamente definito e calcolato come prodotto dei fattori:

$$R = P \times I \times E$$

Dove:

P = probabilità della minaccia	Alta per minacce molto probabili
I = impatto (gravità del danno / effetto)	Alto per danni consistenti
E = efficacia dei controlli	Alto per controlli poco efficaci

- In pratica il rischio viene definito come la probabilità che una minaccia sfrutti una vulnerabilità per generare un impatto nocivo (senza che esista una contromisura che lo impedisca).

Attacchi – Meccanismi - Servizi

🔒 Tanto che si faccia riferimento alla sicurezza di sistemi quanto alla sicurezza delle reti, vi sono alcuni punti fondamentali che devono essere esaminati:

- ✓ **attacchi**: sono tutte le azioni illegali o indebite, volte a compromettere la sicurezza delle informazioni e/o dei sistemi e delle reti;
- ✓ **meccanismi**: si intendono gli strumenti progettati e realizzati per rilevare la presenza di un attacco, per prevenirlo o infine per riparare i danni prodotti dalla sua attuazione
- ✓ **servizi** : sono gli interventi messi in atto per migliorare la sicurezza a livello di sistema e di rete. I servizi svolgono il loro compito facendo uso dei meccanismi disponibili e più adatti all'ambito di intervento

Classification of Attacks



Passive Attacks

- ✓ Riguardano attività di intercettazione e monitoraggio di traffico di rete e flusso di dati. Sono attacchi piuttosto complessi da intercettare in quanto non prevedono azioni attive sul Sistema target.
- ✓ Footprinting
- ✓ Sniffing e eavesdropping
- ✓ Network traffic analysis
- ✓ Decrittazione di traffico con crittografia debole



Active Attacks

- ✓ Riguardano azioni volte a manomettere dati in transito o a interrompere la comunicazione tra i sistemi. Agiscono attivamente sul target, quindi sono facili da rilevare.
- ✓ Dos attack
- ✓ Malware attacks
- ✓ Spoofing attacks
- ✓ Session hijacking
- ✓ MITM Attack
- ✓ ARP poisoning
- ✓ SQL injection
- ✓ XSS Attack



Close-in Attacks

- ✓ Vengono eseguiti quando l'utente malintenzionato si trova in stretta vicinanza fisica con il sistema o la rete di destinazione al fine di raccogliere, modificare o interrompere l'accesso alle informazioni
- ✓ Tali attacchi riguardano molte delle attività classificate come Social Engineering (shoulder surfing, dumpster diving, ecc)

Classification of Attacks



Insider Attacks

- ✓ È un tipo di attacco eseguito da persone considerate fidate dall'obiettivo (es: impiegati) che hanno accesso fisico alla struttura target. L'attaccante sfrutta i propri accessi privilegiati per violare regole o causare intenzionalmente una minaccia alla sua organizzazione
 - ✓ Theft of physical devices
 - ✓ Social Engineering
 - ✓ Data theft
 - ✓ Keyloggers, backdoors, malware



Distribution Attacks

Si verificano quando gli aggressori manomettono hardware o software prima della distribuzione e/o vendita ad aziende e consumatori

- ✓ Modificare hardware o software durante la sua produzione
- ✓ Modificare hardware o software durante la sua distribuzione

Information Security Attack Vectors



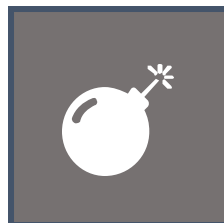
Cloud Computing Threats

Il cloud computing è una **distribuzione on-demand** di funzionalità IT in cui vengono archiviati i dati sensibili delle organizzazioni e dei loro clienti. Il difetto nel cloud applicativo di un client consente agli aggressori di accedere ai dati di altri client



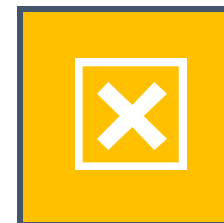
Advanced Persistent Threats (APT)

Un attacco che si concentra sul **furto di informazioni dalla macchina** vittima senza che l'utente ne sia consapevole



Viruses and Worms

La minaccia di rete più diffusa che è in **grado di infettare una rete in pochi secondi**



Ransomware

Limita l'accesso ai file e alle cartelle del sistema informatico e **richiede un pagamento di riscatto online** ai creatori di malware al fine di rimuovere le restrizioni



Mobile Threats

L'attenzione degli aggressori si è spostata sui dispositivi mobili a causa della maggiore adozione di **dispositivi mobili per scopi aziendali e personali** e di controlli di sicurezza relativamente inferiori

Information Security Attack Vectors

Botnet

Un'enorme rete di sistemi compromessi utilizzati da un intruso per eseguire vari attacchi di rete

Insider Attack

Un attacco eseguito su una rete aziendale o su un singolo computer da una persona incaricata (insider) che ha accesso autorizzato alla rete

Web Application Threats

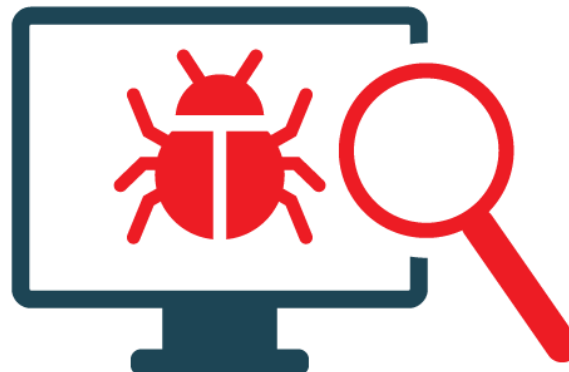
Gli aggressori prendono di mira le applicazioni Web per rubare credenziali, configurare siti di phishing o acquisire informazioni private per minacciare le prestazioni del sito Web e ostacolarne la sicurezza

IoT Threats

I dispositivi IoT includono molte applicazioni software utilizzate per accedere al dispositivo in remoto. I difetti nei dispositivi IoT consentono agli aggressori di accedere al dispositivo da remoto ed eseguire vari attacchi.

Phishing

La pratica di inviare un'e-mail illegittima che afferma falsamente di provenire da un sito legittimo nel tentativo di acquisire informazioni personali o sull'account di un utente



Cosa sono le «vulnerabilità»

- Ma cosa sono quindi le vulnerabilità?
- Una vulnerabilità è una debolezza, una “falla” nel sistema informatico che, se ben sfruttata (*exploitation*), può provocare gravi danni o anche gravi perdite.
- Fondamentalmente esistono tre tipologie di vulnerabilità che corrispondono alle tre componenti principali di un sistema informatico:
 - ✓ Vulnerabilità di rete (per “rete” si intende tutta l’infrastruttura di comunicazione di un sistema informativo)
 - ✓ Vulnerabilità dei sistemi (per “sistema” si intende tutto il software che controlla un apparato hardware dotato di processore e memoria)
 - ✓ Vulnerabilità delle applicazioni (per “applicazione” si intende tutto il software, compilato od interpretato che è funzionante su di un sistema)

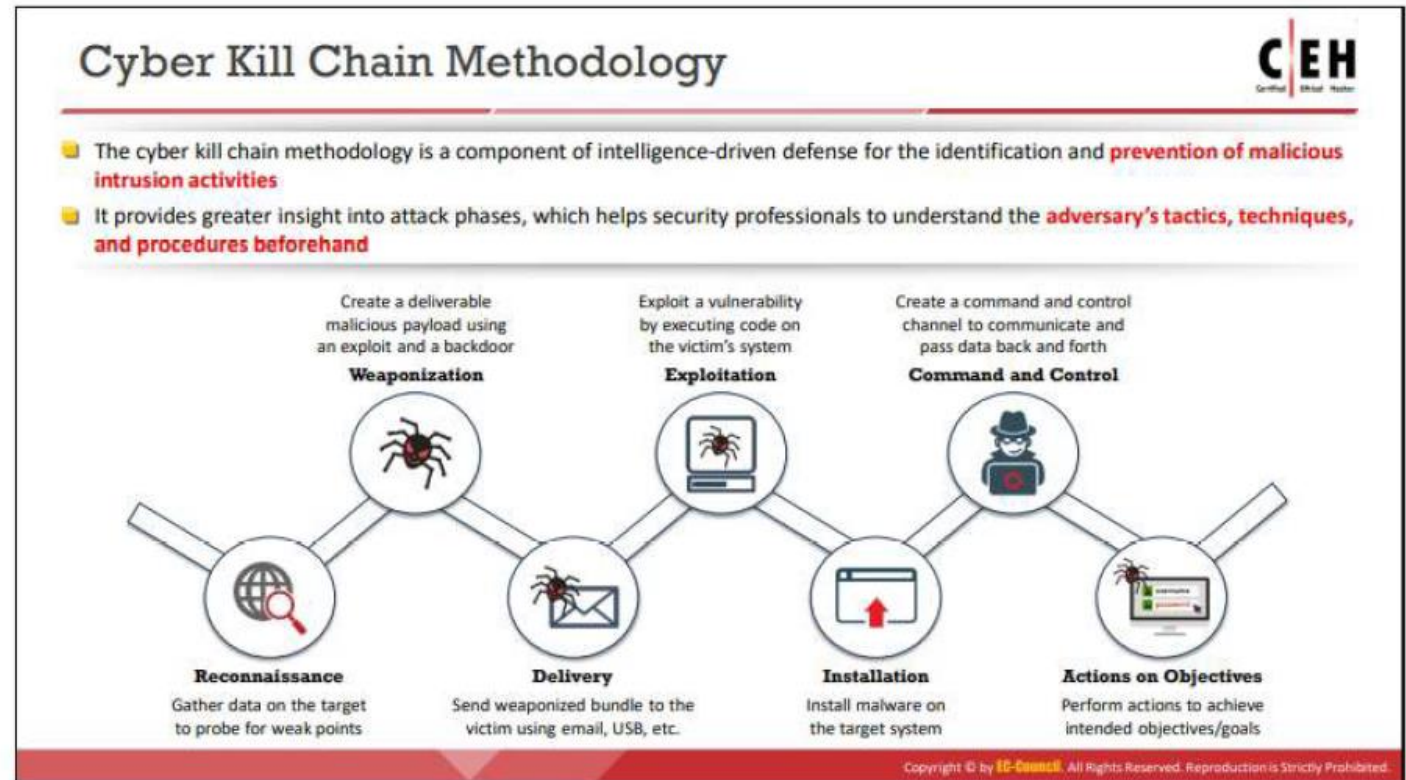


ISTITUTO ELVETICO
FORMAZIONE PROFESSIONALE

Cyber Security: Fundamentals

Cyber Kill Chain Methodology

- La Cyber kill chain methodology è un componente intelligence-driven (basato su intelligence) della difesa informatica.
- Lo scopo è identificare e prevenire le attività intrusive e maligne.
- È un metodo che aiuta i professionisti della sicurezza a identificare quali passi seguire per giungere a un risultato di prevenzione, difesa, contromisura e recupero.



Cyber Security: Fundamentals

Cyber Kill Chain Methodology

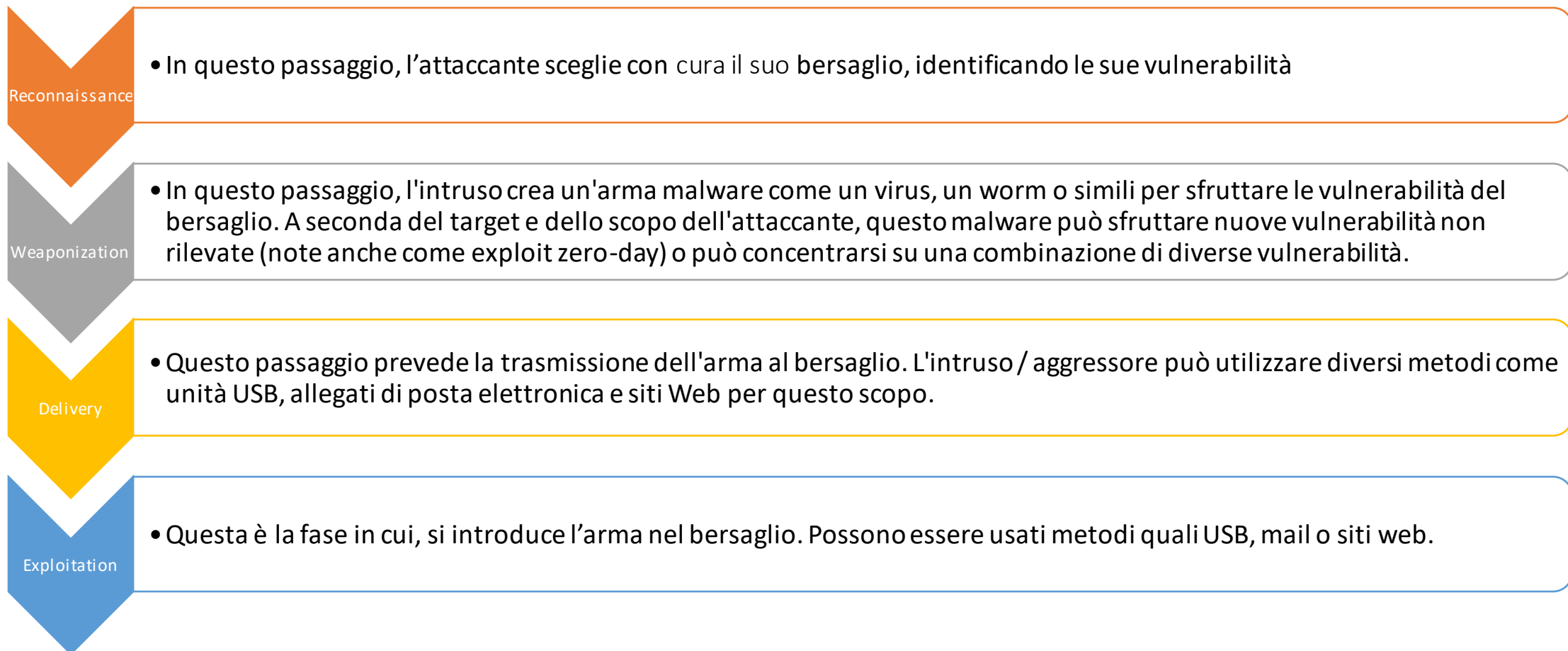
- La Cyber Kill Chain offre una struttura completa che si integra nel modello Intelligence Driven Defense.
- Le intrusioni informatiche sono il peggior incubo per tutti gli utenti internet. Ecco perché molti professionisti e sviluppatori di sicurezza informatica offrono soluzioni uniche per l'identificazione e la prevenzione delle attività di intrusione informatica.
- Il termine "kill chain" è stato utilizzato per la prima volta come un concetto militare che definisce la struttura di un attacco che copre:
 - ✓ L'identificazione del target
 - ✓ L'invio della forza verso l'obiettivo
 - ✓ La decisione e l'ordine di attaccare il bersaglio
 - ✓ La distruzione del bersaglio

Cyber Kill Chain Methodology

- Ispirandosi al concetto dell'intera catena di uccisioni, Lockheed Martin (un'azienda aerospaziale, di sicurezza, di armi, difesa e tecnologie avanzate con sede negli Stati Uniti d'America) ha creato la Cyber Kill Chain.
- È un framework di sicurezza informatica che offre un metodo per affrontare le intrusioni su una rete di computer.
- La Cyber Kill Chain si compone di sette passaggi che mirano a offrire una migliore visibilità degli attacchi, supportando l'analista di attacchi informatici / sicurezza informatica per ottenere una migliore comprensione delle tattiche, delle procedure e delle tecniche dell'avversario. I sette passaggi della Cyber Kill Chain illustrano le diverse fasi di un cyber attacco partendo dalla ricognizione, arrivando fino all'esfiltrazione.

Cyber Security: Fundamentals

Cyber Kill Chain Methodology



Cyber Security: Fundamentals

Cyber Kill Chain Methodology

Installation

- Si crea un accesso per l'attacker. Meglio noto come backdoor

Command and Control

- Il malware fornisce all'attacker accesso alla rete e al sistema

Action and Objective

- Una volta ottenuto l'accesso alla rete o al sistema, l'attacker può portare a termine il suo obiettivo, quindi crittografia dei dati, data exfiltration o distruzione dei dati

Tactics, Techniques, and Procedures (TTPs)

Il termine Tattiche, Tecniche e Procedure (TTP) si riferisce ai modelli di attività e metodi associati a specifici attori delle minacce o gruppi di attori delle minacce



Tactics

Le "tattiche" **sono le linee guida che descrivono il modo** in cui un utente malintenzionato esegue l'attacco dall'inizio alla fine



Techniques

Le "tecniche" sono **i metodi tecnici utilizzati da un utente malintenzionato** per ottenere risultati intermedi durante l'attacco



Procedures

Le "procedure" sono **approcci organizzativi che gli attori delle minacce seguono** per lanciare un attacco

DISASTER RECOVERY PLAN

- ❏ Per **Disaster Recovery Plan (DRP)**, si intende l'insieme di tutte quelle misure tecniche, logistiche e organizzative predisposte da un'azienda per ripristinare dati, applicazioni e sistemi informatici necessari per l'operatività del business (sia che si tratti di un'azienda, ente o associazione), a seguito di eventi in grado di interrompere il regolare svolgimento dell'attività (erogazione di beni o servizi) o addirittura minacciare la stessa sopravvivenza aziendale.
- ❏ Il **Disaster Recovery Plan (DRP)** è il documento che raccoglie tali procedure e che ogni azienda deve predisporre, aggiornare e custodire con cura per poter fronteggiare in modo opportuno eventuali emergenze informatiche. Affinché l'azienda possa rispondere in modo tempestivo ed efficiente a tali situazioni, il Disaster Recovery Plan deve:
 - ✓ identificare i dati e i sistemi che sono critici (ovvero, fondamentali) per l'operatività aziendale
 - ✓ classificare i dati e sistemi critici in base al livello di importanza, assegnando ad essi un valore da 1 a 5
 - ✓ stabilire un livello accettabile di perdita dei dati (o sistemi), ovvero quanti dati (o sistemi) l'azienda può permettersi di perdere senza compromettere la propria sopravvivenza o rischiare il fermo prolungato delle attività (**Recovery Point Objective**).

- La valutazione del rischio è anche conosciuta come "analisi dei rischi" e "calcolo del rischio". Per uniformità, useremo "valutazione dei rischi" come definizione di scelta per questa discussione.
- La valutazione del rischio si occupa delle minacce, vulnerabilità e impatti di una perdita di capacità di elaborazione delle informazioni o una perdita di informazioni stesse.
- Una vulnerabilità è una debolezza che potrebbe essere sfruttata da una minaccia. Ogni rischio che può essere identificata dovrebbe essere delineato, descritto e valutato per la probabilità che si verifichi. La chiave qui è quello di pensare fuori dagli schemi.

- 🔒 I componenti chiave di un processo di valutazione dei rischi
- 🔒 RISK TO WHICH THE ORGANIZATION IS EXPOSED
 - ✓ Questo componente permette di sviluppare scenari che possono aiutare il Security Manager a valutare come meglio affrontare tali rischi. Un sistema, server o applicazioni possono essere esposti a diversi tipi di rischi. È necessario, quindi, stilare un elenco dettagliato di tutti i rischi potenziali.
- 🔒 RISK THAT NEEDS ADDRESSING
 - ✓ Una volta stilato l'elenco dei rischi potenziali, è necessario valutare quali di questi siano reali e quali improbabili. In questa fase è importante e fondamentale una corretta valutazione della probabilità. Ad esempio, spionaggio industriale e furto possono essere auspicabili, ma il rischio che un ciclone danneggi la sala server in una zona geografica nella quale i cicloni non si formano, è molto bassa. Pertanto, dovrebbero essere impiegate maggiori risorse atte ad impedire lo spionaggio o furto rispetto al ciclone
- 🔒 COORDINATION WITH BIA
 - ✓ La componente di valutazione dei rischi, in collaborazione con il business impact analysis (BIA), fornisce all'organizzazione un quadro preciso della situazione in quanto consente all'organizzazione stessa di prendere decisioni intelligenti su come rispondere a vari scenari.
- 🔒 COMPUTING RISK ASSESSMENT
 - ✓ Quando si sta facendo una valutazione dei rischi, una delle cose più importanti da fare è assegnare a ciascun rischio, un indice di priorità. Non tutti i rischi devono essere valutati in modo uniforme perché alcuni hanno maggiore probabilità di accadere rispetto ad altri.

La valutazione di impatto

BIA: Business Impact Analysis

- Business Impact Analysis è il processo relativo alla valutazione di tutti i sistemi critici di un'organizzazione al fine di definire i piani di impatto e recovery. La valutazione BIA non riguarda la valutazione delle minacce esterne o le vulnerabilità ma semplicemente, si focalizza sull'impatto che una perdita potrebbe avere su un'organizzazione.
- Qui di seguito sono spiegati i passaggi chiave per una corretta valutazione di impatto BIA:
 - ✓ Identificare le funzioni critiche: è opportuno chiedersi, quali funzioni sono necessarie per continuare le operazioni fino a quando i servizi vengano ripristinati? In questa fase è fondamentale la pianificazione della continuità operativa (BCP)

La valutazione di impatto

BIA: Business Impact Analysis

- ✓ Dare priorità alle funzioni aziendali critiche: Dopo il verificarsi di un qualsiasi evento, è importante garantire le funzioni operative di base dell'intera organizzazione. Cosa succederebbe, ad esempio, se i tuoi servizi di comunicazione dati diminuissero? Si potrebbero stabilire servizi temporanei, ma probabilmente non sarai in grado di ripristinare completamente capacità di rete.
- ✓ Calculating a Timeframe for Critical Systems: quanto tempo un'organizzazione può sopravvivere senza una funzione critica? Ci sono infatti funzioni che non richiedono un immediato intervento, altre sì. È fondamentale individuarle e soprattutto stabilire il tempo per il ripristino. Esempio: un'azienda che dipende interamente dalla presenza nel web attraverso la sua piattaforma e-commerce. È importante valutare il tempo massimo in cui il sito e-commerce non può essere disponibile.

CALCOLO DEL RISCHIO

- 🔒 Ai fini della valutazione del rischio, sia nel mondo reale e per l'esame, si dovrebbe conoscere con un certo numero di termini per determinare l'impatto di un evento potrebbe avere:
 - ✓ ALE (annualized loss expectancy) è il valore annuale di previsione di perdita. Questa è una misura di quanto monetaria la perdita si potrebbe aspettare in un anno.
 - ✓ SLE (single loss expectancy) è un altro valore monetario, e rappresenta quanto si aspetta di perdere in qualsiasi una volta: la previsione di perdita singola. SLE può essere diviso in due componenti:
 - ✓ AV (asset value - valore patrimoniale)
 - ✓ EF (exposure factor - fattore di esposizione)
 - ✓ ARO (annualized rate of occurrence) è la probabilità, spesso tratte da dati storici, di un evento che si verificano all'interno un anno: il tasso annualizzato di occorrenza.

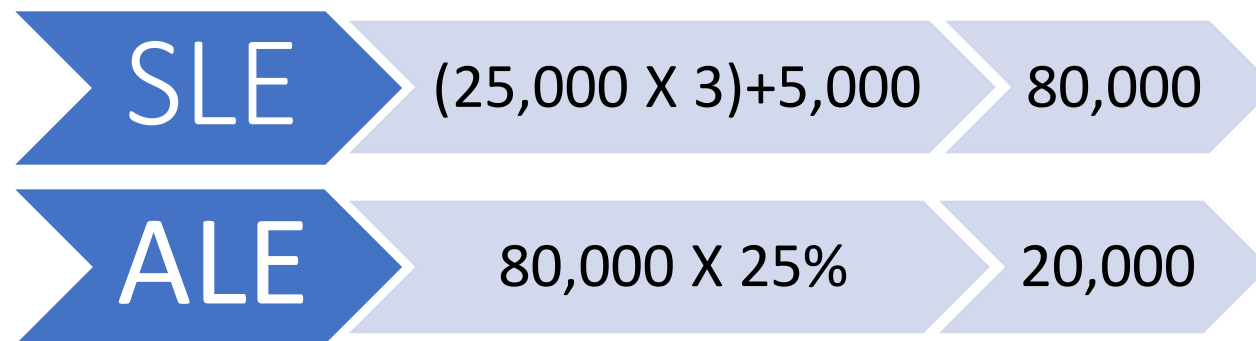
Disaster Recovery Plan

RISK CALCULATIONS

- Quando si calcola la valutazione del rischio, ricordate questa formula:

$$SLE \times ARO = ALE$$

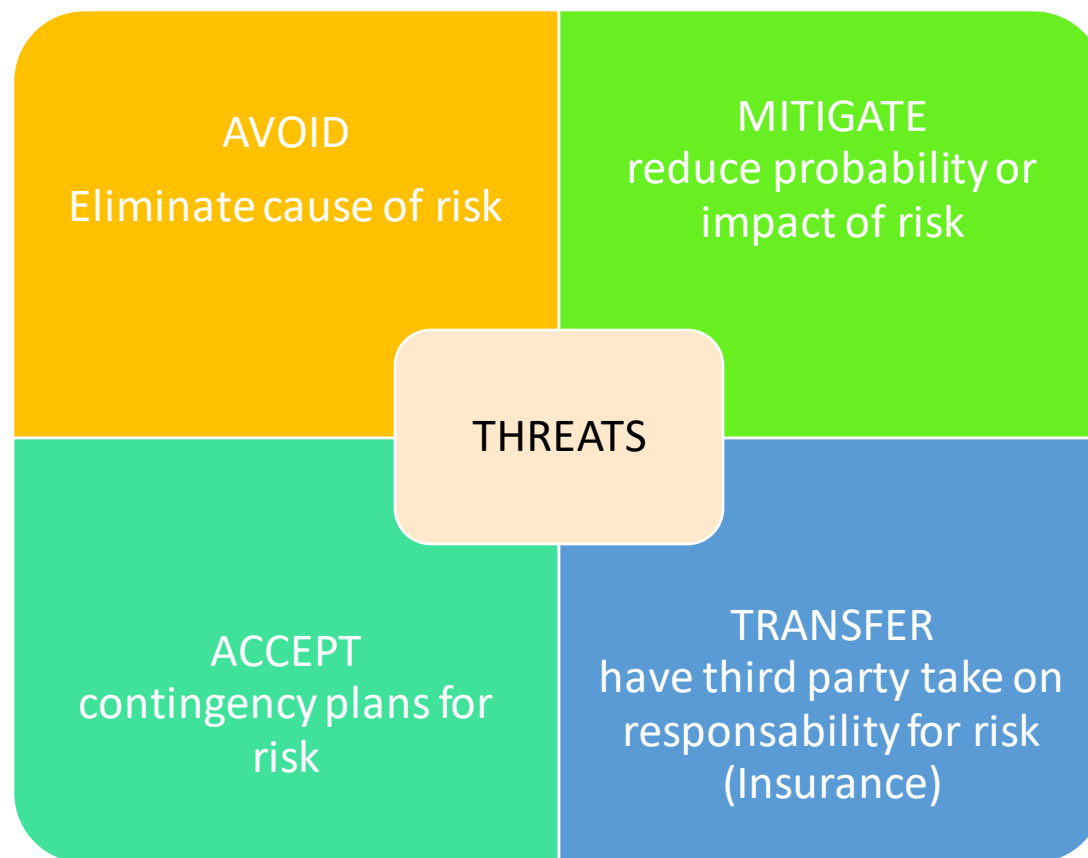
- You're the administrator of a web server that generates \$25,000 per hour in revenue. The probability of the web server failing during the year is estimated to be 25 percent. A failure would lead to three hours of downtime and cost \$5,000 in components to correct. What is the ALE?



- 🔒 You work at the help desk for a small company. One of the most common requests to which you must respond is to help retrieve a file that has been accidentally deleted by a user. On average, this happens once a week. If the user creates the file and then deletes it on the server (about 60 percent of the incidents), then it can be restored in moments from the shadow copy and there is rarely any data lost. If the user creates the file on their workstation and then deletes it (about 40 percent of the incidents), and if it can't be recovered and it takes the user an average of two hours to re-create it at \$12 an hour, what is the ALE?

RISPOSTA AI RISCHI INFORMATICI

- Lo scopo di definire una “risposta al rischio” (*risk response*) è di riportare il rischio residuo (attuale) in linea con il livello di tolleranza al rischio definito dall’azienda. Non si tratta di un compito da svolgere “una volta per tutte” quanto piuttosto di una attività periodica da includere nel ciclo del processo di *risk management*. Per i rischi significativi l’azienda (o l’unità organizzativa) di solito prende in considerazione diversi tipi di risposta ed opzioni.



Elasticity

- ✓ L'elasticità è una delle principali caratteristiche del cloud computing, ovvero la capacità di aumentare le risorse quando necessario.

Scalability

- ✓ È la capacità di un sistema di poter essere implementato sia in positivo che in negativo, in poco tempo. A differenza di un datacenter fisico, un datacenter virtuale, è molto simile da un punto di vista amministrativo e presenta elasticità, scalabilità e così via grazie al modello pay-as-you-go.

High Availability

- ✓ (HA) si riferisce alle misure, quali ridondanza, fail-over e mirroring, utilizzato per mantenere operativi i servizi e i sistemi durante un'interruzione.

Resiliency

- ✓ È la capacità di avviare una operazione di recover rapidamente subito dopo un qualsiasi evento critico.

Risk Terminology

- ***acceptable use policy/rules of behavior*** Agreed-upon principles set forth by a company to govern how the employees of that company may use resources such as computers and Internet access.
- ***annualized loss expectancy (ALE)*** A calculation used to identify risks and calculate the expected loss each year.
- ***annualized rate of occurrence (ARO)*** A calculation of how often a threat will occur. For example, a threat that occurs once every five years has an annualized rate of occurrence of 1/5, or 0.2.
- ***asset value (AV)*** The assessed value of an item (server, property, and so on) associated with cash flow.
- ***business impact analysis (BIA)*** A study of the possible impact if a disruption to a business's vital resources were to occur.
- ***business partners agreement (BPA)*** An agreement between partners in a business that outlines their responsibilities, obligations, and sharing of profits and losses.
- ***exposure factor (EF)*** The potential percentage of loss to an asset if a threat is realized.
- ***maximum tolerable downtime (MTD)*** The maximum period of time that a business process can be down before the survival of the organization is at risk.

Risk Terminology

- **interconnection security agreement (ISA)** As defined by NIST (in Publication 800-47), it is “an agreement established between the organizations that own and operate connected IT systems to document the technical requirements of the interconnection. The ISA also supports a Memorandum of Understanding or Agreement (MOU/A) between the organizations.”
- **mean time between failures (MTBF)** The measurement of the anticipated lifetime of a system or component.
- **mean time to failure (MTTF)** The measurement of the average of how long it takes a system or component to fail.
- **mean time to restore (MTTR)** The measurement of how long it takes to repair a system or component once a failure occurs.
- **memorandum of understanding (MOU)/memorandum of agreement (MOA)** Most commonly known as an MOU rather than MOA, this is a document between two or more parties defining their respective responsibilities in accomplishing a particular goal or mission, such as securing a system.
- **recovery point objective (RPO)** The point last known good data prior to an outage that is used to recover systems.

- **recovery time objective (RTO)** The maximum amount of time that a process or service is allowed to be down and the consequences still to be considered acceptable.
- **Redundant Array of Independent Disks (RAID)** A configuration of multiple hard disks used to provide fault tolerance should a disk fail. Different levels of RAID exist.
- **risk acceptance** A strategy of dealing with risk in which it is decided the best approach is simply to accept the consequences should the threat happen.
- **risk analysis** An evaluation of each risk that can be identified. Each risk should be outlined, described, and evaluated on the likelihood of it occurring.
- **risk assessment** An evaluation of the possibility of a threat or vulnerability existing. An assessment must be performed before any other actions—such as how much to spend on security in terms of dollars and manpower—can be decided.
- **risk avoidance** A strategy of dealing with risk in which it is decided that the best approach is to avoid the risk.
- **risk calculation** The process of calculating the risks that exist in terms of costs, number, frequency, and so forth.

Risk Terminology

- **risk mitigation** A strategy of dealing with risk in which it is decided that the best approach is to lessen the risk.
- **risk transference** A strategy of dealing with risk in which it is decided that the best approach is to offload some of the risk through insurance, third-party contracts, and/or shared responsibility.
- **service-level agreement (SLA)** An agreement that specifies performance requirements for a vendor. This agreement may use mean time before failure (MTBF) and mean time to repair (MTTR) as performance measures in the SLA.
- **single loss expectancy (SLE)** The cost of a single loss when it occurs. This loss can be a critical failure, or it can be the result of an attack.
- **single point of failure (SPOF)** A single weakness that is capable of bringing an entire system down
- **vulnerability** A flaw or weakness in some part of a system's security procedures, design, implementation, or internal controls that could expose it to danger (accidental or intentional) and result in a violation of the security policy.
- **risk** The probability that a particular threat will occur, either accidentally or intentionally, leaving a system vulnerable and the impact of this occurring.